

HO/01/IT/2025-26/83

Date: 22.05.2025

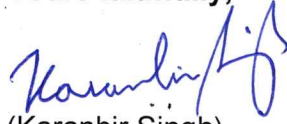
Circular to all Branches & Offices
Issued by Information Technology Department

Re: Cyber Security Policy (Version 1.0) of the Bank

Branches & Offices are hereby informed that the Cyber Security Policy (Version 1.0) of the Bank has been approved by the Hon'ble Board of Directors through agenda item no.10 in its meeting no.01(01/2025) dated 07.05.2025. The policy will come into force with immediate effect & validity of the policy is for next three years from the date of approval. The approved Cyber Security Policy is attached here with this circular.

Kindly bring the content of this policy in the notice of all staff members of the Branches/Offices.

Yours faithfully,



(Karanbir Singh)
General Manager

Enclosure: As above

Cyber Security Policy

(Version – 1.0)

Uttar Pradesh Gramin Bank
Information Technology Department
Head Office, Lucknow

Cyber Security Policy (Version 1.0)

Cyber Security Policy

Document Information

Document Name	Cyber Security Policy
Document ID	Uttar Pradesh Gramin Bank- Cyber Security Policy
Document Owner	CISO
Document Version No.	1.0
Document Version Date	
Prepared By	Information Technology Department
Reviewed By	
Approved By	

Version History since 2024

Version No.	Version Date	Prepared/Revised by
1.0		

Current Version Reviewed by

Version No.	Designation
1.0	General Manager

Distribution List

Version No.	Name	Designation	Department
1.0	N.A.	All Departmental Heads and Heads of Controlling Offices.	All Departments, Controlling Offices and Branches

Cyber Security Policy (Version 1.0)**Table of Contents:**

Sr. No.	Particular	Page No.
01.	Introduction, Purpose, Scope,	04-05
02.	Terms & Definitions	05
03.	Policy Statement, Identify, Protect, Detect, Respond and Recover	05-10
04.	Roles & Responsibilities	10-11
05.	Reference Document	11
06.	Appendix – Suggestive Cyber Security Controls	11-12
07.	Exception	13
08.	Policy maintenance and version control	13

Cyber Security Policy (Version 1.0)

1. Introduction

Information Technology that supports banking business functions are increasingly advanced, pervasive and connected, also they are increasingly being attacked by cyber criminals. Expressive growth of technology in business and the extended use of internet leaves most of the organization infrastructure connected to the cyberspace thus leaving the organization of potential to come under cyber-attacks.

It is important for one to understand the distinction between Cyber Security and Information Security; often there are large overlap of controls in information security and cyber security.

Information Security is completely focused on the confidentiality, Integrity and Availability of the information, where information can be in either electronic format (digital) and hardcopy format.

Cyber security is focused on protection of information in electronic format, organization brand and reputation from the threats originating from cyber space.

For example, threats like dumpster driving, electric power fluctuation, flood, etc., will not be considered in a cyber-security environment, because these threats do not originate from the cyber realm

In short, we can consider Cyber Security as a subset of Information security; however, the cyber security has to remain a distinctive security framework mainly for the reason.

- Cyber Security is all about protecting against threats from cyber realm.
- Cyber Threats are more dynamic and growing at a rapid pace.
- Cyber Security control designs are focused only on electronic format assets only.

Uttar Pradesh Gramin Bank has cutting edge technologies and IT infrastructure connected to the cyberspace for providing leading services to customers. Uttar Pradesh Gramin Bank recognizes the challenges in managing the risks related to cyber security, Also the bank intends to develop cyber security framework that is in-line with RBI/NABARD Cyber Security Framework, our sponsor bank's policies and other best practices to protect bank's valuable assets from cyber-attacks.

To combat growing cyber threats and enhancing the resilience of the banking system to address cyber risks, NABARD vide its communication EC No. 33/DoS-08/2020 Ref No. NB. DoS. PoI. HO./3184/J-1/2019-20 dated 06 February 2020, directed Regional Rural Banks as follows:

"All RRBs should put in place a cyber-security policy, duly approved by their Board, giving a framework and the strategy containing a suitable approach to check cyber threats depending on the level of complexity of business and acceptable levels of risk."

Application of cyber security framework enables communication about security risk priorities and activities in business terms, turning potential organizational risk into competitive advantage.

2. Purpose

The purpose of this cyber security policy is to define strategic guidelines on cyber security framework that effectively detect cyber-attacks on Bank's Cyber infrastructure, business services and other related assets; to respond and recover from those cyber-attacks.

- To safeguard the cyber facing Information Infrastructure of the Bank various types of cyber threats including, but not limited to Denial of Service (Dos), Distributed Denial of Services (DDoS), ransom-ware / crypto ware, destructive malware, business email frauds including spam, phishing, etc.
- To respond, resolve and recover from cyber incidents and attacks through timely information sharing, collaboration and action.

Cyber Security Policy (Version 1.0)

- To establish a framework to enable a safe and vibrant cyber space.
- Foster a culture of cyber security that promotes a safe and appropriate use of cyber space.
- Develop and cultivate cyber security capabilities.
- To create awareness among awareness among the stakeholders including employees

Collectively, these objectives provide the foundation for protecting against and preparing for cyber threats (i.e., a proactive approach to cyber security) as well as detecting, responding to and recovering from threats and challenges (i.e. reactive cyber security efforts).

3. Scope

The Scope of Cyber Security Policy applies to all business services, processes and technology assets that are connected directly or indirectly to the cyber space.

This policy applies to all employees (permanent & contract employees), non-employees (consultants, contractors, vendors, suppliers and customers), business processes, infrastructure and facilities of the Bank spread across all over India. All employees and non-employees shall understand this policy and ensure adherence to its terms.

4. Terms & Definitions

IT Infrastructure: Systems and assets, whether physical or virtual, so vital to the organization that the incapacity or destruction of such systems and assets would have a debilitating impact on cyber security, organizational economic security, user economic security, customer economic security or any combination of those matters.

Cyber Security: The ability to protect or defend the use of cyberspace from cyber-attacks.

Cyber Space: A global domain within the information environment consisting of the interdependent network of information systems infrastructures including the Internet, telecommunications networks, computer systems, and other IT devices.

Risk: A measure of the extent to which an organization/asset is threatened by a potential circumstance or event, and typically a function of: (i) the adverse impacts that would arise if the circumstance or event occurs; and (ii) the likelihood of occurrence.

Current Profile: The Current Profile indicates the cyber security outcomes that are currently being achieved.

Target Profile: The Target Profile indicates the outcomes needed to achieve the desired cyber security risk management goals.

5. Policy Statements

5.1 Identify

It is important to understand the business context, identify the resources that support critical functions and related cyber security risks that enable an organization to focus and prioritize its efforts, consistent with its risk management strategy and business needs.

- Bank shall clearly identify and prepare an inventory of the list of IT infrastructures, business applications, related business services, facilities that are connected to within/outside networks which includes branch networks, external networks like internet, vendors, service providers etc.
- Whenever a new service or asset is introduced in the bank's network or there are any changes to the existing assets, the inventory shall be updated on a continuous basis.
- Business owners shall perform assessments to identify the business criticality of the assets as per **Business Impact Analysis defined in the Business Continuity Policy of the Bank.** The criteria for

Cyber Security Policy (Version 1.0)

identifying the criticality of the assets shall be defined by the Business owners. The criteria shall include but will not be limited to;

- Financial Impact
- Productivity Impact
- Reputation Impact
- Customer Impact
- Degree of Asset Exposure to Cyber Space
- Sensitivity of the data
- Bank shall clearly identify and classify the data handled or processed by the assets, as per the Information Classification Schema defined in Data Classification – Standard and Guideline Document.
- Bank shall define a cyber-security risk management practice that helps it to identify the current profile and the cyber security risk scenarios that apply to each of the critical business services and its associated assets.

5.2 Protect

Based on the risk scenarios and the risk level, Information Security Department should develop an outline that focuses on the assessment and implementation of the cyber security controls describing the bank's desired cyber security outcomes and supports the ability to limit or contain the impact of a potential cyber security event.

- Bank shall develop a target profile for the business services and its associate assets. The target profile shall include controls to protect the assets from cyber security events.
- Based on the control objective, the controls shall be grouped into the 3 types Preventive, Detective and Corrective Controls. (Refer the Appendix for the detailed list of cyber security controls under each type)
- Based on the difference between the current profile and the target profile, the gaps shall be identified and an action plan to remediate the gaps shall be formulated and approved by the business service owners and CISO respectively.
- Priority for the controls in the action plan shall be decided on applicable risk basis.
- Bank shall design and implement an IT architecture that is conducive to security measures at any point in time.
- Bank shall control installation of software/applications on end user PCs, laptops, workstations, servers, mobile devices etc.
- Bank shall develop baseline secure configuration documents for all categories of assets.
- Bank shall put in required measures to ensure security of applications during all the stages of application lifecycle. Refer to the Bank's Application Security – Standard & Guideline Document for various stages and the respective security requirements.
- Bank shall implement vendor risk management process that includes, vendor risk profiling, vendor on-boarding checks, periodic vendor audits, etc.,
- Bank shall implement controls to mitigate the risk related to using removable media and mobile devices.
- Bring your own device (BYOD) i.e. personal computing devices are not permitted unless specifically approved, for accessing systems hosted within Bank's secure environment and accessible from the Bank's WAN. Only applications which are accessible through internet such as E-mails, Intranet site, E-learning portals etc. can be accessed from personal devices.
- Bank shall develop appropriate control implementation strategies that clearly document the scope of control implementation, milestones, responsibilities, approach desired effectiveness of the control, use cases, and associated risk scenarios.
- Developed control strategies have to be approved by the CISO before implementation.

Cyber Security Policy (Version 1.0)

- All the critical IT assets in the infrastructure should be configured to generate audit logs, audit logs include minimum information to uniquely identify the log for example by including a date, timestamp, source addresses, destination addresses, user ID, action performed, and various other useful elements of each packet and/or event and/or transaction.
- Bank shall develop user security awareness programs for the bank's employees, users and management. The security awareness program shall promote and establish a risk aware culture within the bank.
- The user security awareness program shall be developed in alignment to the existing **Security Training – Standard & Guideline Document**.
- For all the cyber security controls, develop performance measurement metrics that provide for prospective and retrospective measures, like key performance indicators and key risk indicators.
- Bank shall setup authentication framework for customers and also other safeguards to keep the customer information secure.
- Bank shall develop customer security awareness program for its customer. The program shall educate the customers on the risk of phishing emails, phishing sites, sharing their login credentials /passwords etc. to any third party vendors, and the negative consequences thereof.
- The customer security awareness program should be designed in such a way that it encourages the customers to report cyber security risk events like phishing emails/ phishing sites/ phishing calls, etc.,
- Bank shall arrange for independent compliance check at regular intervals.

5.3 Detect

The nature of cyber-attacks are such that they can occur at any time and in a manner that may not have been anticipated, so there shall be continuous surveillance in place to monitor the cyber security risk events. As part of the detect section, bank shall develop and implement safeguards to identify the occurrence of a cyber-security event.

- Bank shall perform periodic vulnerability assessment, configuration audit and penetration testing on all assets in the cyber space, to detect any vulnerabilities /weakness existing in the assets that can be exploited by the cyber threats
- Baseline security configuration documents for all assets (Servers/databases/network/middlewares) should be documented and vetted by senior management of IT and shared with CISO and IS Audit department.
- Configuration audit shall consider the checks in baseline security configuration document that was developed for all categorized assets.
- Penetration testing of public facing systems and other critical applications should be carried out by professionally qualified teams/individuals.
- Reported Vulnerabilities/weakness should be remediated with appropriate patches from OEM/vendors, or fine tuning of configurations, and/or suitable substitute controls.
- Remediation of vulnerabilities/weakness should be performed as per the BOB RRB DC Patch Management – Standard & Guideline Document.
- Bank shall establish red teaming practice to periodically evaluate and detect the network, systems and applications vulnerabilities.
- Red Teams shall identify the vulnerabilities and the business risk, assess the efficacy of the defences and check the mitigating controls already in place by simulating the objectives and actions of an attacker.
- As per NABARD guidelines regarding Cyber Security framework for Regional Rural Banks, Uttar Pradesh Gramin Bank comes under Level II criteria, as a proactive measure, Bank will setup a Cyber

Cyber Security Policy (Version 1.0)

SOC, in coordination with BOB RRB DC & CISO to monitor, detect, and respond to cyber risk in real time.

- The operating model for the Cyber SOC shall be 24/7 to enable continuous monitoring as bank's critical business services and infrastructures are provided round the clock and throughout the year to its customers.
- Cyber SOC related roles and responsibilities shall be clearly defined, documented and approved by the Top Management Steering Committee on Information Security. The Cyber SOC function shall report directly to the CISO.
- Based on the Cyber SOC roles and responsibilities defined, Bank shall document a skill, competency and training plan for the staffs in SOC.
- Cyber SOC should have a well-defined Cyber Security Incident management process in place which explains in details of the various activities, responsibilities involved in the incident lifecycle. This process should be in alignment to the Security Incident Management – Standard & Guideline Document.
- The Cyber SOC should account for proactive monitoring and management capabilities with sophisticated tools for detection (SIEM), quick response and tools for sound analytics (Security Analytics tools).
- Cyber SOC setup shall have systems/mechanism/process to perform the following when detecting and responding to cyber security risk.
 - Event and Log Analysis
 - Incident Reporting
 - Incident Triaging and classification
 - Incident investigation, forensics and deep packet analysis
 - Cyber Kill chain analysis
 - Dynamic Behaviour Analysis. – Preliminary static & dynamic analysis and collecting Indicators of Compromise (IOC)
 - Threat Intelligence and Security Analytics with good dash board, showing the Geo-location of the IP's
 - Incident Response procedures
 - Prediction of future cyber-attacks by analysing honey pots, security analytics, etc.
- Bank shall implement a detailed Incident reporting form/tool that captures all the incident stages specific information's.
- Bank shall implement process for risk based transaction monitoring as part of fraud risk management system across all critical delivery channels like ATM, Internet Banking, Mobile Banking, NEFT, RTGS, UPI, Payment Gateway etc.
- There shall be comprehensive reports and dashboards developed and the SOC performance shall be reported directly to the CISO on a periodic basis. Some of the report templates shall include the following but not limited to:
 - Number of cyber incidents reported
 - Number of open critical incidents
 - Percentage of Incidents resulted in system/user/compromise
 - Incident detected at which stage
 - Number of incidents successfully responded
 - Most frequent type of cyber-attacks
 - Most targeted business services/applications/assets etc

Cyber Security Policy (Version 1.0)

5.4 Respond & Recover

Bank is expected to be well prepared to face emerging cyber-threats such as 'zero-day' attacks, remote access threats, and targeted attacks. Respond function related activities, support the ability to contain the impact of a potential cyber security event. Bank should be prepared with threat scenarios specific cyber crisis management plans, incident response procedure steps, forensic analysis to collect and preserve digital evidences, mitigation measures to stop the cyber-attacks.

- **Bank shall develop Cyber Crisis Management Plan (CCMP)** for all cyber threat scenarios that apply to the critical business services and assets.
- The Cyber Crisis Management Plan should include detailed guidelines on the following.
 - Monitoring and Detection of scenarios specific cyber threats
 - Indicators of Attack (IOA) and Indicators of Compromise (IOC)
 - External and Internal Communication
 - Forensic Investigation
 - Law Enforcement
 - Breach Communication and Notification
 - Detailed steps on Containment and Response
- The developed Cyber Crisis Management Plan should be reviewed by the CISO and approved by the Hon'ble Board.
- The adequacy of and adherence to cyber resilience should be assessed by bank and measured through performance indicators to assess the level of risk /preparedness.
- Cyber Mock drills shall be conducted on a bi-annual basis to test the effectiveness of the CCMP. The Cyber mock drills shall be conducted in co-ordination with all involved parties including Vendors, ISP, Regulatory Bodies, CERT-IN and law enforcement agencies.
- The Cyber Mock drills shall evaluate the following areas during the testing.
 - Involved Personnel know their roles and order of operations when a response is needed.
 - Events are reported consistent with established criteria.
 - Information is shared consistent with response plans.
 - Coordination with stakeholders occurs consistent with response plans.
 - Voluntary information sharing occurs with external stakeholders to achieve broader cyber security situational awareness.
- Bank shall conduct root-cause analysis to ensure adequate response and support recovery activities are clearly identified. During RCA the following shall be considered.
 - Events and Notifications from all detection control systems are investigated.
 - Understand the impact of the incident
 - Forensic Investigations are performed to collect more evidences and trails.
 - Digital evidences collected shall be preserved with proper chain of custody.
 - Incidents specific response plans are identified.
- Cyber SOC function shall be provided with pre-authorization for deploying containment measures to mitigate the cyber security risk. The pre-authorization includes provision of adequate resources with incident response skills, Forensic Investigation tools, access privilege (may be administrative privilege) to the IT assets involved, etc.
- As part of response, the Cyber SOC shall involve specialist authorized 3rd parties/vendors to help in investigation and response. Adequate approvals shall be obtained from the CISO before involving 3rd parties/vendors.
- Cyber SOC shall ensure the response activities performed to prevent propagation of an event, mitigate its effects, and eradicate the incident are documented with detailed information.

Cyber Security Policy (Version 1.0)

- For the purpose of improving the CCMP Plan, bank shall incorporate the lessons learnt from current and previous detection/response activities.
- Recovery processes and procedures shall be executed and maintained to ensure timely restoration of systems or assets affected by cyber security events.
- Cyber SOC Restoration activities shall be coordinated with internal and external parties, such as coordinating centres, Internet Service Providers (ISPs), owners of attacking systems, victims, CERT-IN, and vendors.
- Cyber SOC shall ensure that recovery activities are communicated to internal stakeholders and management teams in a timely manner.
- Notification of breach or cyber security events, recovery activities related communications to customers and external stakeholders shall be routed through authorized channel like IT Department. Also, ensure only the bare minimal required information is shared to avoid any reputational damage.

6. Roles & Responsibilities

Sr. No.	Roles	Responsibilities
1.	TMSC	• Review the performance indicators to assess the level of cyber risk/preparedness • Assess the results of mock drills • Review Cyber Security Policy and approve minor revisions of this policy and recommend major revisions to the Board for approval
2.	WGIS	• Review and approve Cyber Crisis Management Plan • Develop and measure the performance indicators to assess the level of cyber risk/preparedness • Conduct mock cyber drills • Implement corrective measures post mock drills to improve response
3.	CISO	• Periodically review SOC performance • Communicate recovery actions to management and internal stakeholders • Define a cyber-security risk management practice • Develop user security awareness program for employees • Conduct periodic vulnerability assessment and penetration testing • Establishing red team practices • Document skills, competency and training plan for the staffs in SOC • Proactive monitoring, detection and response to cyber events • Setup systems/processes to detect and respond to cyber security risks • Develop Cyber Crisis Management Plan • Develop and measure the performance indicators to assess the level of cyber risk/preparedness. • Bank "CISO" should place the status of Cyber Security to Board/Sub-Committee of Board on periodic basis.
4.	Head of IT	• Provide pre-authorization to deploy containment measures to mitigate cyber security risk • Develop appropriate control implementation strategies • Develop performance measurement metrics • Develop and measure the performance indicators to assess the level of cyber risk/preparedness • Execute recovery processes and procedures to ensure timely restoration of systems or assets affected by cyber security events • Communicate recovery actions to management and internal stakeholders

Cyber Security Policy (Version 1.0)

		• Prepare an inventory of the list of IT infrastructures, business applications, related business services, facilities • Update inventory
5.	IS Audit	• Identification of cyber security implementation gaps • Conduct periodic configuration audits • Conduct root cause analysis • Involve authorized specialists third parties in cyber investigations and response • Independent compliance check at regular intervals
6.	Business Owners	• Identify and classify data handled or processed by assets • Remediation of cyber security gaps • Remediation of findings in vulnerability assessments, configuration audits and penetration testing • Execute recovery processes and procedures to ensure timely restoration of systems or assets affected by cyber security events • Coordinate restoration activities between internal and external parties
7.	Digital Banking	• Develop security awareness program for customers • Perform risk based transaction monitoring • Notify customers in case of cyber breach
8.	Public Relations	• Notify external stakeholders in case of cyber breach

7. Reference Documents

1. Cyber Security Framework - RBI
2. Cyber Security Policy-Bank of Baroda
3. Information Security Policy-Bank of Baroda (BOB_ISMS_ISPO_V5.2)

8. Appendix – Suggestive Cyber Security Controls

Control Type	Cyber Security Control
Preventive Controls	1. Network security controls that protect data that is transmitted processed and accessed within and also outside the bank's network. Network security controls (State-full Inspection Firewalls, Application layer firewalls, IPS, VPN gateway, Proxy, etc.,) to protect the bank's network from various network attacks and intrusions. 2. Secure access to the bank's assets/services from within/outside bank's network by protecting data/information at rest (e.g. using encryption, if supported by the device) and in-transit (e.g. using technologies such as VPN or other secure web protocols, etc.) 3. White listing of authorized applications/software libraries to prevent unauthorized software execution on end-user PCs, laptops, workstations, servers, mobile devices, etc. 4. Implementation of patches released by OEMs/Vendors to block exploiting of known vulnerabilities 5. Environmental controls like air-conditioners, fire detection and suppression systems, water leakage detection systems, physical access controls, power supply, UPS, DG, etc., 6. Baseline secure configurations control for all categories of IT assets (end-points/workstations, mobile devices, operating systems, databases, applications,

Cyber Security Policy (Version 1.0)

	network devices, security devices, security systems, etc.), throughout the lifecycle (from conception to deployment) and carry out reviews periodically 7. Strong authentication and encryption technology (WPA2, WPA PSK) for wireless networks 8. Centralized authentication and authorization systems (IAM solutions) for accessing all categories of IT assets 9. Enforcement of Bank's Password policy through (IAM solutions, SSO solutions) 10. Two/Multi-factor authentication systems to protect from unauthorized access through brute force attack, password guess attack, dictionary attack etc., 11. Anti-Malware and Anti-Mobile code protection controls with advanced real time threat detection, behavioural detection capabilities to prevent end points assets like workstations, laptops, mobile devices, operating systems, applications, databases etc., from malware infections. 12. Anti- Phishing controls to protect end users from social engineering techniques. 13. Email security controls to protect end users from email spoofing, identical mail domains, malware as attachment, malicious links etc., 14. Secure web gateways with deep packet inspection capabilities to scan http, https traffics 15. Implement Data leakage prevention solutions for data processed in all internal end point devices, vendor end point devices and data stores to prevent information leakage threats. 16. Use advanced endpoint security systems to limit or block the usage of removable devices from copying/transferring data.
Detective Controls	1. Implementing SIEM and integrating all log sources to the SIEM to effectively monitor the cyber security events. 2. Establish a Cyber SOC setup to monitor the cyber security events and detect the cyber threats in a real time. 3. Integration of SIEM with all security controls to correlate and analyze the alert logs. 4. Configure SIEM with use cases that covers the risk scenarios that were identified for the organization its business services and infrastructure assets. 5. Perform Vulnerability Assessment, Configuration Audit and Penetration testing to detect any vulnerability in the network/systems/applications. 6. Honey pot technology deployed outside the perimeter firewall can help detect the types of cyber-attacks targeted at the organization. 7. Cyber Security performance metrics reports and dashboards could be implemented to detect the current status. 8. Periodic Vendor Risk audits to find the status of the controls implemented at vendor locations and the risk posture. 9. Develop and monitor key risk indicators related to the risk scenarios that apply to the business services. 10. Digital Forensic investigation process that helps in collecting and preserving digital evidence of a cyber-attack.
Corrective Controls	1. Apply the security patches as per Bank's existing Patch management process/policy 2. Development of Cyber Crisis management plans that includes detailed information on how to detect, respond, contain, notify and recover from a cyber- security event or threat scenarios. 3. Execution of CCMP as response to various 4. Cyber Mock drills to test the effectiveness of Cyber Crisis Management plans.

Cyber Security Policy (Version 1.0)

9. Exceptions

Where there is a justifiable business need that requires actions to be performed which are in conflict to this document, such exceptions shall be reported to the TMSC and approval shall be obtained from Hon'ble Board. Such approvals shall be valid for a pre-defined period after which it shall be re-evaluated and re-approved.

10. Policy maintenance and version control

The policy shall be reviewed on annual basis i.e. one year from the date of approval by the Hon'ble Board or till the next approval whichever is earlier.

Any fresh/additional guidelines issued by RBI/NABARD/Sponsor Bank or any such statutory/regulatory/supervisory etc. body shall supersede this policy with concurrence of the Chairman subject to reporting/informing the Hon'ble Board.

The validity of the policy shall be three years from the date of approval of the Board. In case the policy cannot be reviewed on or before due date, The Chairman is authorized for allowing to continue with the policy for further three months from the due date of review.

End of the document